

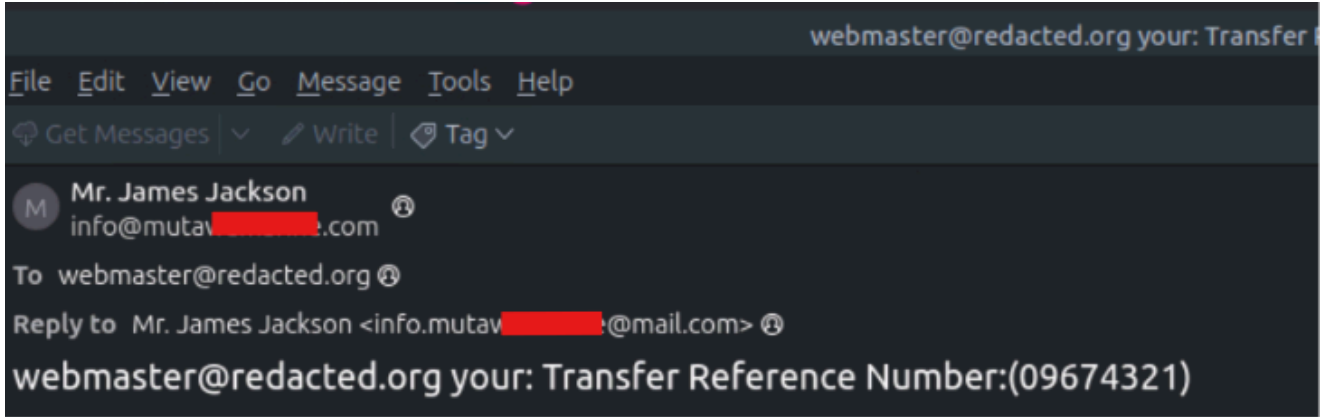
The Greenholt Phish

[Kaynak](#) - [Hazırlayan](#)

Phishing E-Posta Analizi ve Yüzey İstihbaratı (Surface Intelligence)

Bir SOC (Security Operations Center) analisti olarak incelemeye aldığımız şüpheli e-posta, Greenholt PLC çalışanına ulaşmış bir **Phishing** (Oltalama - kurbanı manipüle ederek hassas bilgi, yetki veya para transferi elde etme) girişimidir. Gelen kutusundaki e-posta mesajı yüzeysel olarak incelendiğinde, doğrudan hedefe yönelik olmayan, jenerik bir "Good day webmaster@redacted.org" hitabıyla başlamaktadır. Kurumsal iletişim standartlarına aykırı olan bu durum, otomatik araçlarla gönderilmiş bir yığınsal (bulk) saldırının ilk habercisidir.

Aciliyet hissi yaratmak ve kurbanı eyleme geçirmek amacıyla konu satırında (Subject) resmi bir işlem algısı yaratan bir referans numarası kullanılmıştır. Konu satırında yer alan Transfer Reference Number değeri burada açıkça gözükmemektedir.



Good day webmaster@redacted.org ,



As instructed, funds has been transferred to your account this morning via SWIFT.

Details are as below and a receipt of payment is attached.

Interbank Transfer Reference Number: 09674[redacted]

Transaction Status: Successful

Transaction Date / Time: 10-06-2020 09:18:55

> 1 attachment: SWT_#09674321____PDF____.CAB 400 KB

Aynı arayüzde, gönderici (Sender) kısmındaki görünen ad (Display Name) olarak ayarlanmıştır. Görünen adın kurumsal bir kimlik yerine bireysel bir şahıs izlenimi vermesi, ancak e-postanın genel bir "info" adresinden gelmesi şüpheli bir asimetri yaratmaktadır.

E-Posta Kaynak Kodunun (Header Analysis) İncelenmesi

Bir e-postanın sadece grafik arayüzdeki görünümüne güvenmek kritik bir güvenlik hatasıdır. Saldırganın gerçek izlerini sürmek için e-postanın ham kaynak koduna (Raw Source / Headers) inmemiz gerekir.

```
Source of: file:///home/ubuntu/Desktop/challenge.eml? - Mozilla Thunderbird

File Edit View Help
James
@mutawamarine.com
webmaster@redacted.org
Mr. James Jackson
bstei...
iy we...
ucte...
are a...
ık Tra...
ion S...
ion Date / Time: 10-06-2020 09:18:55

0TEw0w1CkWz4gxhNU4FH4Iub03b9TLvUoX9KLEfx3De15yPTf8xXY7NY_kzA
aCwKTjp4FaeT2Mk1Pq5P48DF.dB6hdMTmCoowuSwouW2M9Yp4euqKNzGrLcf
2KcRMROfFVcKDwXSaHw4tMhKvXSH0KiWVFpXPaMmt2c0cklVpwZMyql8w8W
PlponBle66yIqNuYV.vt64i52HFh0jNwcuohMo7MA7DmMP.OtkdwLLUqLS
68Afikwfw3Sppf_pTqtP6NPF2wuAsJIaT7_QQ.4x3khgYrC4jTmXjVBWdVRV
wT0AdlQ716U8TVp.0AKvevKfMzfZoT0TsGLuQU.w8uZhv_6mwKB4sW7Pbhr
B1RJadC0va2CJiCbAClQnapm5egSIEqxkboy8i0Ufz0qkD1a1_tn5nv1Ix0
bcqer07cnAjpN1amFuvC8gjD345qb6k9l7h7a8TFsv_67Nkrok_.M4_MRZcf
.iuxPcffe2r1ocaSfWQg6yof0WQta51sbWQidg7B_4XR2_6cbg8Ui39t2v2Y
bgwISohtB1urfpr.b1SANr7fvE2Zzvzjz4_4PbBt8DevFUB7Pjq0GiAe_Nx_
Ypw8ploFasyilk4T9f5e5ryqAu.HToIegVimVa4xwuzjbNvaE7Tsm4m3vepb
zGZI1BWuDLQ-
X-Originating-IP: [x.x.x.x]
Received: from 10.197.41.148 (EHL0 sub.redacted.com) (x.x.x.x)
by mta4212.mail.bf1.yahoo.com with SMTP; Wed, 10 Jun 2020 05:58:54 +0000
Received: from hwsrv-737338.hostwinddns.com ([192.168.1.1]:51810 helo=mutawamarine.com)
by sub.redacted.com with esmtp (Exim 4.80)
(envelope-from <info@mutawamarine.com>)
id 1jissD-0004g5-Ts
for webmaster@redacted.org; Wed, 10 Jun 2020 01:02:04 -0400
Reply-To: "Mr. James Jackson"
From: "Mr. James Jackson"
To: webmaster@redacted.org
Subject: webmaster@redacted.org your: Transfer Reference Number:(09674321)
Date: 09 Jun 2020 22:58:27 -0700
Message-ID: <20200609225823.DFAEAAF31A6B7414@mutawamarine.com>
MIME-Version: 1.0
Content-Type: multipart/mixed;
boundary="-----NextPart_000_0012_BDB07B06.81B59493"
X-Spam-Status: No, score=-0.5
```

Kaynak kod incelendiğinde, e-postayı gönderen adresin (From:)

██████████@mutawamarine.com olduğu görülmektedir. Ancak, saldırı kurbanının yanıt vermesi durumunda bu yanıtların nereye gideceğini kontrol etmek zorundadır. Bu nedenle Reply-To: (Yanıtla) başlığı manipüle edilmiştir.

DİKKAT: E-posta yönlendirme manipülasyonu tespit edilmiştir. Kurban bu e-postaya yanıt verdiğinde mesaj gerçek From adresine değil, saldırı kurbanının kontrolündeki

██████████@mail.com adresine gidecektir. From ve Reply-To adresleri arasındaki bu uyumsuzluk (mismatch), e-postanın sahte (spoofed) olduğunu kanıtlayan kesin bir **IoC** (Indicator of Compromise - Uzlaşma Göstergesi) değeridir.

Saldırının kökenini bulmak için Received: başlıklarını (headers) aşağıdan yukarıya doğru kronolojik olarak analiz ediyoruz. En alttaki (ilk) Received: başlığı, e-postayı internete çıkaran orijinal sunucuyu gösterir. Bu analize göre e-postanın kaynak IP adresi (Originating IP) burada tespit edilmiştir.

OSINT ve Ağ İstihbaratı: Altyapı Doğrulaması

Tespit ettiğimiz IP adresinin hangi otonom sisteme (AS) veya servis sağlayıcıya ait olduğunu bulmak için WHOIS (Alan adı veya IP adresinin kayıt bilgilerini sorgulayan protokol) incelemesi yapıyoruz. Sorgu sonucunda bu Originating IP adresinin sahibinin (Organization) bir hosting/altyapı sağlayıcısı olduğu doğrulanmıştır.

 Domains Hosting Websites Email Security Whois Deals	
Parent:	NET192 (NET-192-0-0-0)
NetType:	Direct Allocation
OriginAS:	
Organization:	[REDACTED] (HOSTP-7)
RegDate:	2012-11-12
Updated:	2026-05-13
Comment:	Geofeed https://geofeeds.oniaas.io/geofeeds.csv
Ref:	https://rdap.arin.net/registry/ip/192.119.64.0
OrgName:	[REDACTED]
OrgId:	HOSTP-7
Address:	325 Delaware Avenue
Address:	Suite 300
City:	Buffalo
StateProv:	NY
PostalCode:	14202
Country:	US
RegDate:	2016-06-06
Updated:	2025-10-05
Ref:	https://rdap.arin.net/registry/entity/HOSTP-7
OrgAbuseHandle:	NETAB23-ARIN
OrgAbuseName:	NETABUSE
OrgAbusePhone:	+1-905-315-3455
OrgAbuseEmail:	net-abuse-global@hostpapa.com
OrgAbuseRef:	https://rdap.arin.net/registry/entity/NETAB23-ARIN
OrgTechHandle:	NETTE9-ARIN
OrgTechName:	NETTECH

Bir e-postanın gerçekten iddia ettiği alan adından (mutawamarine.com) gelip gelmediğini doğrulamak için DNS tabanlı e-posta kimlik doğrulama mekanizmalarını kontrol etmeliyiz. MxToolBox kullanarak alan adının **SPF** (Sender Policy Framework - Bir alan adı adına e-posta göndermeye yetkili IP adreslerini belirten TXT DNS kaydı) politikasını inceliyoruz.

 **TOOLBOX®**
SUPERTOOL

SuperToolMX LookupBlacklistsDMARCDiagnosticsEmail HealthDNS LookupAnalyze Headers

SuperTool Beta9

mutawamarine.comSPF Record Lookup

spf:mutawamarine.comFind ProblemsSolve Email Delivery Problems

 **Outlook.com has new sender requirements!**
Get ready with MxToolbox Delivery Center

protection.outlook.com

Prefix	Type	Value	PrefixDesc	Description
	v	spf1		The SPF record version
+	include	spf.protection.outlook.com	Pass	The specified domain is searched for an 'allow'.
-	all		Fail	Always matches. It goes at the end of your record.

Yukarıdaki çıktı, alan adının tam SPF kaydıdır. `v=***` kullanılan SPF versiyonunu, `include` parametresi yalnızca Microsoft Outlook altyapısının e-posta göndermeye yetkili olduğunu belirtir. Sondaki `-all` (Hard Fail) parametresi ise, Outlook altyapısı dışındaki **hiçbir IP adresinin** bu alan adı adına mail atamayacağını, atan e-postaların doğrudan reddedilmesi gerektiğini söyler. Bizim tespit ettiğimiz kaynak IP adresi bu yetkili listede yoktur, bu da e-postanın kesinlikle sahte olduğunu teknik olarak kanıtlar.

SPF tek başına yeterli değildir, sunucunun ihlal durumunda nasıl davranacağını belirleyen **DMARC** (Domain-based Message Authentication, Reporting, and Conformance - SPF ve DKIM sonuçlarını değerlendirerek e-postanın nasıl işleneceğini belirten kural seti) kaydını da sorguluyoruz:

SuperToolMX LookupBlacklists**DMARC**DiagnosticsEmail HealthDNS LookupAnalyze Headers

 **DMARC Check Tool - Check DMARC Records for Errors**

Domain Name

info@mutawamarine.comDMARC LookupSolve Email Delivery Problems


SUPERTOOL

SuperToolMX LookupBlacklistsDMARCDiagnosticsEmail HealthDNS LookupAnalyze He

SuperTool Beta9

mutawamarine.comDMARC Lookup

dmarc:mutawamarine.comFind ProblemsSolve Email Delivery Problems

v=DMARC1;

Tag	TagValue	Name	Description
v	DMARC1	Version	Identifies the record retrieved as a DMARC record. It must be the first tag in the list
p	quarantine	Policy	Policy to apply to email that fails the DMARC test. Valid values can be 'none', 'quar
fo	1	Forensic Reporting	Provides requested options for generation of failure reports. Valid values are any c

Test	Result
✓ DMARC Record Published	DMARC Record found
✓ DMARC Syntax Check	The record is valid
✓ DMARC Multiple Records	Multiple DMARC records corrected to a single record.

Bu DMARC kaydında `p=quarantine` politikası (Policy) uygulanmıştır. Bu parametre, e-postayı alan sunucuya "Eğer SPF veya DKIM kontrolleri başarısız olursa, bu e-postayı silme ancak kullanıcının Spam/Junk klasörüne karantinaya al" emrini verir. `fo=1` (Forensic Reporting) ise herhangi bir kimlik doğrulama mekanizması başarısız olduğunda alan adı sahibine adli bilişim raporu gönderilmesini sağlar.

Zararlı Eklenti (Malicious Attachment) Analizi

E-posta kaynağı incelendiğinde Content-Transfer-Encoding: base64 ibaresi görülmektedir. SMTP (Simple Mail Transfer Protocol) metin tabanlı bir protokol olduğu için, eklentiler (binary dosyalar) ağda bozulmadan taşınabilmek için **Base64** algoritmasıyla şifrelenmeden (yalnızca kodlanarak) metne dönüştürülür.


```
mes Jackson
nutawam
ster@red File Edit View Help
Source of: file:///home/ubuntu/Desktop/challenge.eml? - Mozi
r. James. <p><span style=3D"color: #666699;">&nbsp;</span></p>
ter@re <p><strong><span style=3D"vertical-align: inherit;"><span style=3D"vertical=
-align: inherit;">Best regards,</span></span></strong></p>
webma <p>&nbsp;</p>
<p><strong><span style=3D"vertical-align: inherit;"><span style=3D"vertical=
-align: inherit;">Mr. James Jackson</span></span></strong></p>
<p><strong><span style=3D"vertical-align: inherit;"><span style=3D"vertical=
-align: inherit;">Accounts Payable</span></span></strong></p>
<p><strong><span style=3D"vertical-align: inherit;"><span style=3D"vertical=
-align: inherit;">SEC MARINE SERVICES PTE LTD</span></span></strong></p>
ted, fur <p><strong>&nbsp;</strong></p>
<div>&nbsp;</div>
-----= NextPart_000_0012_BDB07B06.81B59493
Content-Type: application/octet-stream; name="SWT_#<span style=3D"color: #666699;">&nbsp;</span>.CAB"
Content-Transfer-Encoding: base64
Content-Disposition: attachment; filename="SWT_#<span style=3D"color: #666699;">&nbsp;</span>.CAB"

UmFyIRoHAQD0LsZoDAEFCAHAQGmgZmAAC0iALA0AgML3IAZBICYHiC7XfKHgBMAFLNXVF8j
MDk2NzQzMjFfX1BERi5jb20KAwIhQPwb6T7WAY/1cFBncEVEIldmYDZ2IsJEgUiUy1EHFBUY
jBUQYBBUFAYQFRRkFQUGAUBhHxptm2yCggzij4BI0dVYV3eYLV9+56663x3x36Jdt5d3qC
tVVarVQ6u72+lq8CfPtVq8u8wvjje/5fRf/kALoMgAQG/+QAzgyAAwL/5AGEDIAEBv/kAZgM
gAKCwURmFpdWlpaXi4n58HAWkv4+rQf+MSfM6fhM6lv6LqU3gLCp5a71e486/x0beY6Kvx1
lioyMjcCddLudHYKM0vY/2x2m1HX6Nu13qjMzMdPVA0DfgQK2Igr/asnwWhfwrS4tsi28HsW
wGYQ45akus43IYEhdPxcSHegxXzRuC5Q8Hk+40zQj/VjnQd0G8/UCD7UtJBfgL/+JSeEadlw
v/x/hyIkn9sJd8AHmqY67yGBCp+KVEugVa5/ICudUjo+0uoSItoF2mPsYwLFkRMA+jZ7vfY0
rQyqhzRBesof7YVqg/mpo0IC2NyHBibqDgF/7K0gggnWVscNvS4P57+ihjn/yfzR0qp32kSjp
ynX6VXXS2fp+c4GC2/VpDrtde9T/Y97y29mdizn9mFMLWNA66+Y5HB/VeztvrG7WtprF+Lre
Attachment: SWT_#<span style=3D"color: #666699;">&nbsp;</span>.CAB
```

Eklentinin adı **SWT_# .PDF.CAB** olarak belirlenmiştir. Dosya adındaki birden fazla alt çizgi ve sahte "PDF" uzantısı, kullanıcının görsel algısını manipüle etmeye yönelik klasik bir çift uzantı (double extension) aldatmacasıdır.

Zararlı analizi (Malware Analysis) yapmak için dosyayı izole bir ortama indirip kimliğini doğrulamamız gerekir. Bunun için dosyanın **SHA256** (Secure Hash Algorithm 256-bit - Veri bütünlüğünü doğrulamak ve benzersiz kimlik oluşturmak için kullanılan kriptografik özet fonksiyonu) hash değerini alıyoruz.

```
ubuntu@tryhackme: ~/Downloads
File Edit View Search Terminal Help
ubuntu@tryhackme:~$ ls
Desktop Documents Downloads Music Pictures Public Templates Videos snap
ubuntu@tryhackme:~$ cd Downloads
ubuntu@tryhackme:~/Downloads$ ls
SWT_...PDF_.CAB thunderbird.tmp
ubuntu@tryhackme:~/Downloads$ sha256sum SWT_...PDF_.CAB
2e91c533615a9bb8929ac4bb76707b... SWT_...PDF_.CAB
ubuntu@tryhackme:~/Downloads$
```

Bu komut, hedef dosyanın içeriğini matematiksel bir fonksiyondan geçirerek benzersiz bir parmak izi oluşturur. Eğer dosyanın içindeki tek bir bit bile değişseydi, bu hash değeri tamamen farklı olurdu. Komut çıktısı sonucunda dosyanın SHA256 Hash değeri görülebiliyoruz.

ÖNEMLİ: Zararlı yazılımı kendi ortamımızda çalıştırmak (Dynamic Analysis) yerine, elde ettiğimiz hash değerini VirusTotal gibi global tehdit istihbarat platformlarında sorgulayarak Statik Analiz (Static Analysis) gerçekleştiriyoruz.

VirusTotal sonuçlarına göre:

50
/ 63
Community Score

50/63 security vendors flagged this file as malicious

2e91c533615a9bb8929ac4bb76707b2444597ce063d84a4b33525e25074fff3f
SWT_...PDF_.CAB
attachment spreader

Size
KB
Last Analysis
4 days ago

DETECTION DETAILS RELATIONS COMMUNITY 4

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Basic properties

MD5	f4dd3456cdb1976a145c1179a4d461ec
SHA-1	5a2bb8188377c15c036843b4a6ab9b0c0f2c1607
SHA-256	2e91c533615a9bb8929ac...
SSDEEP	12288:Mj6ygt8RoYqMAnuL8l0A81aBYolm9+X3B4k56:EggRJCul87tolC+X3O
TLSH	T12C94238893562439A8F7385DAFD0CFB5EFE898E74E8F97709CFD609E5D140446205AC2
File type	...
Magic	...
TrID	compressed archive (v5.0) (61.5%) compressed archive (gen) (38.4%)
Magika	...
File size	KB (409868 bytes)

- Dosyanın boyutu burada açıkça görülebiliyoruz.

- Zararlı yazılım geliştiricisi dosya uzantısını .CAB (Windows Cabinet Archive) olarak ayarlamış olsa da, sistemlerin dosya türünü belirlemek için kullandığı asıl yapı olan Magic Bytes (Dosyanın ilk birkaç baytında yer alan, dosyanın gerçek formatını belirten imza) incelendiğinde, bu eklentinin aslında görünenden tamamen farklı bir türü olduğunu görüyoruz. Siber saldırganlar, ağ güvenliği cihazlarının kurallarını yani indirme engellerini vb. atlatmak için uzantı sahteciliği (Extension Spoofing) yaparlar.

Bu derinlemesine analiz sonucunda; gönderici adreslerinin manipüle edildiği, e-posta kimlik doğrulama mekanizmalarının (SPF) ihlal edildiği ve zararlı bir arşiv dosyasının PDF/CAB maskesi altında kurbanı ulaştırılmaya çalışıldığı kesin olarak kanıtlanmıştır.